

INTERNAL AUDIT PROGRAMME

Organization: VertexOne Digital Services

Document Type: ISMS Internal Audit Programme

Standard: ISO/IEC 27001:2022

Reference: Clause 9.2 — Internal Audit

Status: Approved

Prepared By: Junior GRC Analyst

Approved By: CISO

1. Purpose

This Internal Audit Programme defines VertexOne Digital Services' systematic and multi-cycle approach to auditing its Information Security Management System (ISMS), in accordance with **ISO/IEC 27001:2022 Clause 9.2 — Internal Audit**.

The programme is designed to provide assurance that the ISMS:

- Conforms to the requirements of ISO/IEC 27001:2022.
- Conforms to VertexOne's own documented information security requirements.
- Is effectively implemented and maintained.
- Supports continuous improvement and organizational readiness for external certification.

2. Audit Objectives

The objectives of the internal audit programme are to:

1. Verify conformity of the ISMS with ISO/IEC 27001:2022 requirements.
2. Verify conformity with VertexOne's documented information security policies, procedures, and requirements.
3. Assess the operating effectiveness of implemented information security controls.
4. Identify gaps, weaknesses, and opportunities for improvement.
5. Provide management with assurance regarding the effectiveness of the ISMS.
6. Prepare VertexOne for potential external ISO/IEC 27001 certification audits.

3. Audit Scope

The audit programme covers the organization's ISMS and all **25 Annex A controls selected in the Statement of Applicability (SoA)**.

The selected controls will be reviewed through a **rolling 12-month audit programme**, with audit frequency determined by control importance, associated risk, and organizational priorities.

4. Audit Criteria

Internal audits will evaluate the ISMS and applicable controls against the following criteria:

- ISO/IEC 27001:2022 requirements.
- VertexOne Digital Services' Information Security Policy.
- VertexOne's Information Security Risk Register.
- VertexOne's Statement of Applicability (SoA).
- Applicable internal policies, procedures, standards, and documented requirements.
- Defined control objectives and implementation requirements.

5. Audit Frequency

A **full ISMS review will be performed annually**.

Controls associated with the organization's highest-priority risks will receive additional audit attention and will be reviewed **semi-annually**.

The currently identified high-priority risks include:

- **R-001**
- **R-002**
- **R-004**

Audit frequency may be adjusted based on significant changes in risk, control performance, incidents, organizational changes, or management direction.

6. Audit Resources

The **GRC Manager** is designated as the lead auditor for the internal audit programme.

Where the GRC Manager personally operates or implements a control under review, a suitably competent **cross-trained peer reviewer** will be assigned to conduct the audit activity.

Adequate time, access to relevant documentation, personnel, systems, and evidence will be provided to support effective audit execution.

7. Auditor Competence and Independence

Internal auditors must possess appropriate knowledge and competence to perform assigned audit activities.

The designated lead auditor has completed **ISO/IEC 27001 Internal Auditor training**.

To maintain objectivity and independence:

- Auditors will not audit controls they personally implemented.
- Auditors will not audit controls they directly operate.
- Where independence cannot be maintained, an appropriately qualified peer reviewer will be assigned.
- Audit conclusions will be based on objective evidence and documented audit criteria.

8. Annual Audit Schedule

Audit Cycle	Primary Audit Focus	Timing
Cycle 1	Access management, endpoint protection, security awareness, vulnerability management, backup, and supplier security	Month 6
Cycle 2	Configuration management, incident management, cryptography, and monitoring activities	Month 9
Cycle 3	Full ISMS review covering all 25 selected Annex A controls	Month 12

The schedule may be revised where significant changes in organizational risk, security incidents, control performance, or business requirements warrant additional audit activity.

9. Audit Programme Governance

The GRC function is responsible for maintaining this Internal Audit Programme and ensuring that planned audits are performed according to the approved schedule.

Audit results, identified nonconformities, observations, and opportunities for improvement will be documented and communicated to relevant management personnel.

Where audit findings require corrective action, the responsible control or process owner will be assigned appropriate remediation actions and target dates.

Follow-up activities will be performed to verify that agreed corrective actions have been implemented and are effective.

10. Programme Review

This Internal Audit Programme will be reviewed at least annually and updated when necessary to reflect:

- Changes to the ISMS scope.
- Changes to the risk profile.
- Significant changes to information security controls.
- Major incidents or control failures.
- Organizational or regulatory changes.
- Results of previous internal or external audits.
- Management review decisions.

Document Approval

Role	Responsibility	Status
Prepared By	Junior GRC Analyst	Prepared
Reviewed By	GRC Manager	Reviewed
Approved By	CISO	Approved

Document Status: Approved

Review Frequency: Annual

Next Review: To be determined according to the ISMS review cycle.